

Appunti — Modulo D12: L'Intelligenza Artificiale e l'AI Act

Corso: Diritto dell'Informatica T **Fonte:** 12_DirInfo_2026_AI_Act_DEF.pdf (prof. Claudia Cevenini) **Normativa:** Regolamento (UE) 2024/1689 del 13 giugno 2024

Quadro Normativo

Regolamento (UE) 2024/1689 del 13 giugno 2024 — il primo quadro giuridico sull'IA a livello mondiale. [fonte: PDF]

Tre caratteristiche fondanti: [fonte: PDF] - Primo quadro giuridico sull'IA a livello mondiale - Promuove un'IA affidabile in Europa - Stabilisce norme **basate sul rischio** per gli sviluppatori e gli operatori di IA

Imprecisione corretta: Lorenzo ha scritto “deve ancora entrare in vigore (pianamente applicabile 2 agosto 2026)”. Il Regolamento è già **in vigore dal 1° agosto 2024** — vigore applicabilità. L'applicabilità piena arriva il 2 agosto 2026, ma la legge esiste già e alcune disposizioni (divieti, alfabetizzazione) sono già applicabili dal 2 febbraio 2025.

Tappe di Applicazione [fonte: PDF]

Questa sezione non era presente negli appunti grezzi.

Data	Cosa diventa applicabile
1 agosto 2024	Regolamento in vigore
2 febbraio 2025	Divieti (pratiche vietate, art. 5) + obblighi di alfabetizzazione
2 agosto 2025	Norme di governance + obblighi per modelli GPAI
2 agosto 2026	Piena applicazione (tutto il resto)
2 dicembre 2027	Sistemi ad alto rischio standalone (Allegato III) — prorogato dal Digital Omnibus
2 agosto 2028	Sistemi ad alto rischio embedded in prodotti (Allegato I) — prorogato dal Digital Omnibus

§1 — Perché una Legge sull'IA?

La ratio della legge è **garantire che gli europei possano fidarsi dell'IA**. [fonte: PDF]

La maggior parte dei sistemi di IA non pone rischi e può essere di grande utilità. Alcuni sistemi presentano rischi che devono essere affrontati per prevenire ed evitare risultati indesiderati — qualcuno potrebbe essere stato indebitamente svantaggiato nell'accesso all'università o in un'assunzione, una valutazione o una diagnosi medica potrebbe essere errata. [fonte: PDF]

Oggetto della legge [fonte: PDF]

Migliorare il funzionamento del mercato interno e **promuovere la diffusione di un'intelligenza artificiale (IA) antropocentrica e affidabile**, garantendo nel contempo un **livello elevato di protezione della salute, della sicurezza e dei diritti fondamentali**, compresi la democrazia,

lo Stato di diritto e la protezione dell'ambiente, contro gli effetti nocivi dei sistemi di IA nell'Unione, e **promuovendo l'innovazione**. [fonte: PDF]

La legge sull'IA stabilisce: [fonte: PDF] - a) **regole armonizzate** per l'immissione sul mercato, la messa in servizio e l'uso dei sistemi di IA nell'Unione - b) **divieti** di talune pratiche di IA - c) **requisiti specifici** per i sistemi di IA ad alto rischio e **obblighi** per gli operatori di tali sistemi - d) **regole di trasparenza armonizzate** per determinati sistemi di IA - e) **regole armonizzate per l'immissione sul mercato** di modelli di IA per finalità generali (GPAI) - f) regole in materia di **monitoraggio** del mercato, **vigilanza** del mercato, governance ed esecuzione - g) **misure a sostegno dell'innovazione**, con particolare attenzione alle PMI, comprese le start-up

Imprecisione corretta: Lorenzo ha scritto “(questa è uguale alla prima dai)” in riferimento alla lett. e). Non è uguale alla lett. a). Lett. a) riguarda i **sistemi di IA in generale**; lett. e) riguarda specificamente i **modelli GPAI** (General Purpose AI), che hanno un regime normativo distinto. La distinzione sistema di IA / modello GPAI è uno dei punti chiave di D12.

La lett. f) (“monitoraggio del mercato, vigilanza del mercato, governance ed esecuzione”): Lorenzo ha chiesto cosa significano queste cose. - **Monitoraggio del mercato:** raccolta dati e sorveglianza post-immissione — verificare che i sistemi continuino a rispettare i requisiti dopo essere entrati sul mercato, non solo prima - **Vigilanza del mercato:** attività delle autorità nazionali di controllo (market surveillance authorities) che possono ordinare ritiri, sospensioni, indagini - **Governance:** la struttura istituzionale — chi fa cosa: Commissione europea (AI Office per GPAI), autorità nazionali competenti, Comitato europeo per l'IA - **Esecuzione:** applicazione concreta delle sanzioni e delle misure correttive

La lett. g) cita le PMI: Lorenzo ha chiesto cosa sono. **PMI = Piccole e Medie Imprese** (in inglese: SMEs, Small and Medium Enterprises). Nell'UE: imprese con meno di 250 dipendenti e fatturato annuo 50 milioni di euro o totale di bilancio 43 milioni. L'AI Act prevede agevolazioni per PMI e start-up: accesso a sandbox normativi (ambienti di test regolamentati) e, nel sistema sanzionatorio, si applica il minore tra la soglia fissa in euro e la percentuale del fatturato.

La legge sull'IA NON si applica: [fonte: PDF]

- ai sistemi immessi sul mercato, messi in servizio o utilizzati esclusivamente per **scopi militari, di difesa o di sicurezza nazionale**
- ai sistemi di IA o modelli di IA specificamente sviluppati e messi in servizio al solo scopo di **ricerca e sviluppo scientifici**
- alle **persone fisiche** che utilizzano sistemi di IA nel corso di un'attività non professionale puramente personale

§2 — Definizioni Chiave

Sistema di IA [fonte: PDF]

Un **sistema automatizzato** progettato per funzionare con **livelli di autonomia variabili** e che può presentare **adattabilità dopo la diffusione** e che, per obiettivi espliciti o impliciti, **deduce**

dall'input che riceve come generare output quali previsioni, contenuti, raccomandazioni o decisioni che possono influenzare ambienti fisici o virtuali.

Tre tratti costitutivi: (1) automatizzato; (2) autonomia variabile + adattabilità post-diffusione; (3) deduce output da input. Un sistema che si limita a eseguire regole fisse scritte da un programmatore non è un sistema di IA ai sensi della legge.

Lorenzo ha chiesto: “(in che senso può presentare adattabilità dopo la diffusione?)” **Adattabilità post-diffusione** significa che il sistema può **modificare il proprio comportamento** dopo essere stato messo sul mercato, sulla base di nuovi dati o dell'esperienza accumulata durante l'uso — senza che il fornitore intervenga manualmente. È la caratteristica che distingue l'IA da un software tradizionale: un filtro antispam con regole fisse non si “adatta”; un modello ML che affina le sue previsioni in base ai nuovi email degli utenti sì. Questa capacità è rilevante perché rende più difficile valutare il rischio a priori — il sistema che esce dal laboratorio può comportarsi diversamente dopo mesi di uso reale.

Rischio [fonte: PDF]

La **combinazione della probabilità del verificarsi di un danno e la gravità del danno stesso**.

Fornitore [fonte: PDF]

Una persona fisica o giuridica, un'autorità pubblica, un'agenzia o un altro organismo che **sviluppa** un sistema di IA o un modello di IA per finalità generali o che **fa sviluppare** un sistema di IA e **immette tale sistema o modello sul mercato o mette in servizio il sistema di IA con il proprio nome o marchio**, a titolo oneroso o gratuito.

Ottima osservazione: Lorenzo ha sintetizzato correttamente — “Il fornitore è chi mette il proprio nome/marchio sul sistema — che lo abbia sviluppato direttamente o commissionato.” Questa è la chiave per distinguerlo: il marchio, non lo sviluppo fisico.

Deployer [fonte: PDF]

Una persona fisica o giuridica, un'autorità pubblica, un'agenzia o un altro organismo che **utilizza un sistema di IA sotto la propria autorità**, tranne nel caso in cui il sistema di IA sia utilizzato nel corso di un'attività personale non professionale.

Distinzione fornitore/deployer correttamente segnalata da Lorenzo: “fornitore sviluppa e immette sul mercato; il deployer usa. Stessa azienda può essere entrambe le cose in contesti diversi. Obblighi distinti per ciascuno.” Questa distinzione è esattamente quella che la professoressa usa per valutare la comprensione del modulo.

Incidente grave [fonte: PDF]

Un incidente o malfunzionamento di un sistema di IA che, direttamente o indirettamente, causa una delle conseguenze seguenti: - a) il **decesso** di una persona o **gravi danni alla salute** di una persona - b) una **perturbazione grave e irreversibile** della gestione o del funzionamento delle **infrastrutture critiche** - c) la **violazione degli obblighi** a norma del diritto dell'Unione intesi a proteggere i **diritti fondamentali** - d) **gravi danni alle cose o all'ambiente**

§3 — Alfabetizzazione in Materia di IA

I **fornitori** e i **deployer** dei sistemi di IA adottano **misure** per garantire nella misura del possibile un **livello sufficiente di alfabetizzazione** in materia di IA del loro **personale** nonché di **qualsiasi altra persona** che si occupa del funzionamento e dell'utilizzo dei sistemi di IA per loro conto. [fonte: PDF]

Applicabile dal **2 febbraio 2025**. Grava sia su chi sviluppa sia su chi usa — non solo sui tecnici, ma su tutto il personale che interagisce con l'IA.

§4 — Approccio Basato sul Rischio: i 4 Livelli

La legge sull'IA stabilisce **4 livelli di rischio** per i sistemi di IA. [fonte: PDF]

RISCHIO INACCETTABILE - pratiche vietate

ALTO RISCHIO - obblighi rigorosi

RISCHIO LIMITATO - obblighi di trasparenza

RISCHIO MINIMO O NULLO - nessuna norma specifica

Il livello di rischio determina il regime normativo applicabile. Non si tratta di un continuum: ciascun livello ha un insieme specifico di obblighi (o nessuno, per il minimo).

§5 — Rischio Inaccettabile: Pratiche Vietate

Include i sistemi di IA considerati una **chiara minaccia alla sicurezza, ai mezzi di sussistenza e ai diritti delle persone**. Sono definite **8 pratiche vietate**. Applicabili dal **2 febbraio 2025**. [fonte: PDF]

Lorenzo ha chiesto: “fornisci esempi tangibili e una spiegazione concisa ma completa di tutte queste pratiche.” Di seguito tutte e 8, con testo dal PDF e un esempio concreto per ciascuna.

Pratica 1 — Tecniche subliminali o manipolative [fonte: PDF]

Sistemi di IA che utilizzano **tecniche subliminali** (agiscono senza che la persona ne sia consapevole) o **tecniche volutamente manipolative/ingannevoli** che distorcono materialmente il comportamento di una persona, pregiudicando la sua capacità di prendere una decisione informata, causando o potendo causare un **danno significativo**.

Esempio: un'app di e-commerce che rileva momenti di vulnerabilità emotiva dell'utente (orario notturno, navigazione ansiosa) e attiva messaggi di scarsità fittizia (“solo 1 rimasto!”) per indurre acquisti compulsivi senza che l'utente ne sia consapevole. → Caso 3 del PDF. Il criterio comune: l'utente non può prendere una decisione consapevole.

Pratica 2 — Sfruttamento delle vulnerabilità [fonte: PDF]

Sistemi che **sfruttano le vulnerabilità** di una persona fisica o di un gruppo, dovute all'**età**, alla **disabilità** o a una **specificità situazione sociale o economica**, con l'obiettivo o l'effetto di **distorcere materialmente il comportamento** causando o potendo causare un danno significativo.

Esempio: un'app di gioco d'azzardo che identifica utenti in stato di dipendenza (tramite pattern di gioco compulsivo) e invia promozioni mirate nei momenti di maggior vulnerabilità. Diversa dalla pratica 1: qui non c'è manipolazione inconscia ma sfruttamento di una debolezza già esistente.

Pratica 3 — Social scoring [fonte: PDF]

Sistemi di IA per la **valutazione o classificazione di persone fisiche** sulla base del loro **comportamento sociale** o di caratteristiche personali, in cui il punteggio comporta: (i) trattamento pregiudizievole in **contesti non collegati** a quelli in cui i dati sono stati raccolti; (ii) trattamento **ingiustificato o sproporzionato** rispetto al comportamento.

Esempio: un e-commerce che assegna un punteggio ai clienti (basato su recensioni negative, resi frequenti, interazioni online) e li discrimina nell'accesso a offerte, prezzi o spedizioni prioritarie. → Caso 4 del PDF. Analogo esplicito al sistema di credito sociale cinese — vietato nell'UE in qualsiasi forma.

Pratica 4 — Previsione del rischio di reato [fonte: PDF]

Sistemi di IA per **valutare o prevedere il rischio** che una persona commetta un **reato, unicamente sulla base della profilazione** o della valutazione dei suoi tratti e caratteristiche della personalità. **Eccezione:** non si applica ai sistemi che supportano la valutazione umana già basata su fatti oggettivi e verificabili.

Esempio: un sistema che analizza il profilo social di una persona (post, like, amicizie) e assegna un punteggio di "rischio criminale" usato per intercettazioni preventive — senza che ci siano fatti concreti. È la "pre-crime detection" di Minority Report: vietata perché presuppone colpevolezza da profilazione. **Connessione con D11:** questa pratica è il confine tra IA lecita e illecita nella prevenzione del reato — direttamente collegata ai temi di D11 su presunzione di innocenza.

Pratica 5 — Scraping di immagini facciali [fonte: PDF]

Sistemi che **creano o ampliano banche dati di riconoscimento facciale** mediante **scraping non mirato** di immagini facciali da **internet** o da **telecamere a circuito chiuso**.

Esempio: Clearview AI — ha costruito un database con oltre 30 miliardi di immagini scaricate da internet senza consenso. → Caso 1 del PDF. Il "non mirato" è il criterio discriminante: raccogliere immagini in blocco da internet viola la pratica; raccogliere immagini specifiche di un indagato (autorizzato da un'autorità giudiziaria) no.

Pratica 6 — Inferenza delle emozioni sul lavoro e a scuola [fonte: PDF]

Sistemi per **inferire le emozioni di una persona fisica** nell'ambito del **luogo di lavoro** e degli **istituti di istruzione**, salvo uso per **motivi medici o di sicurezza**.

Esempio: telecamere IA installate da un datore di lavoro per analizzare le espressioni facciali dei dipendenti durante le riunioni e valutare produttività o coinvolgimento. → Caso 5 del PDF. L'eccezione “motivi di sicurezza” copre ad esempio il rilevamento della sonnolenza nei conducenti professionisti (camionisti, piloti).

Pratica 7 — Categorizzazione biometrica per inferire categorie protette [fonte: PDF]

Sistemi di **categorizzazione biometrica** che classificano individualmente le persone sulla base dei loro **dati biometrici** per trarre inferenze in merito a **razza, opinioni politiche, appartenenza sindacale, convinzioni religiose o filosofiche, vita sessuale o orientamento sessuale**. Eccezione: etichettatura/filtraggio di set biometrici acquisiti legalmente nell'attività di contrasto.

Esempio: un sistema che analizza le caratteristiche del viso di un candidato a un colloquio per inferire il suo orientamento politico o religioso e usarlo nella selezione. Collegato al GDPR: queste sono categorie “sensibili” (art. 9 GDPR) la cui elaborazione è già limitata — l'AI Act aggiunge il divieto specifico dell'inferenza biometrica.

Pratica 8 — Identificazione biometrica remota “in tempo reale” in spazi pubblici [fonte: PDF]

Uso di sistemi di **identificazione biometrica remota “in tempo reale” in spazi accessibili al pubblico** a fini di **attività di contrasto**, a meno che — e nella misura in cui — l'uso sia strettamente necessario per uno dei seguenti obiettivi tassativi: - i) **ricerca mirata di vittime** di sottrazione, tratta, sfruttamento sessuale; **ricerca di persone scomparse** - ii) **prevenzione di una minaccia specifica, sostanziale e imminente** per la vita/incolumità fisica o attacco terroristico - iii) **localizzazione o identificazione di sospettato** di reato grave (pena massima 4 anni) ai fini di indagini penali

Esempio: telecamere IA che confrontano i volti delle persone in piazza con database di sospettati in tempo reale — vietato di default. Le 3 eccezioni sono tassative: fuori da queste ipotesi, anche le forze dell'ordine non possono usarlo. Nota: l'identificazione biometrica **retroattiva** (su filmato già registrato) non è vietata — è ad alto rischio.

Criterio comune alle 8 pratiche

Tutte e 8 ledono **diritti fondamentali non negoziabili**: autonomia decisionale, dignità, non discriminazione, presunzione di innocenza, privacy. Il criterio comune non è il danno effettivo ma il **rischio strutturale** — alcune pratiche sono vietate perché il danno potenziale è così grave e la libertà personale così compromessa che nessun beneficio economico o di sicurezza può giustificarle.

§6 — Sistemi di IA ad Alto Rischio

I casi d'uso dell'IA che possono comportare **gravi rischi per la salute, la sicurezza o i diritti fondamentali** sono classificati come ad alto rischio. [fonte: PDF]

Categorie [fonte: PDF]

Area	Esempi
Infrastrutture critiche	Componenti di sicurezza nei trasporti
Istruzione	Sistemi che determinano l'accesso all'istruzione (punteggio esami)
Componenti di sicurezza	IA applicata alla chirurgia assistita da robot
Occupazione	Software di selezione CV per le assunzioni
Servizi essenziali	Credit scoring che nega l'accesso a un prestito
Biometria	Identificazione biometrica remota retroattiva (es. identificare un taccheggiatore da filmato)
Attività di contrasto	Valutazione affidabilità prove, poligrafo IA
Migrazione e frontiere	Esame automatizzato domande di visto
Giustizia	Soluzioni IA per preparare sentenze dei tribunali

Distinzione pratica vietata vs alto rischio: le pratiche vietate sono **divieti assoluti** — non esiste un modo legale di usarle, indipendentemente dai controlli. I sistemi ad alto rischio sono **ammessi** ma soggetti a obblighi rigorosi prima di entrare sul mercato. L'identificazione biometrica remota **in tempo reale** è vietata (pratica 8); quella **retroattiva** su filmato è ad alto rischio (ammessa con obblighi).

Obblighi per i sistemi ad alto rischio [fonte: PDF]

I sistemi di IA ad alto rischio sono soggetti a **obblighi rigorosi** prima di poter essere immessi sul mercato: - adeguati **sistemi di valutazione e mitigazione dei rischi** - **alta qualità delle serie di dati** per ridurre i rischi di risultati discriminatori - **registrazione dell'attività** per garantire la tracciabilità dei risultati - **documentazione dettagliata** per consentire alle autorità di valutarne la conformità - **informazioni chiare e adeguate** per l'operatore - adeguate **misure di sorveglianza umana** - **elevato livello di robustezza, cibersecurity e accuratezza**

Caso Amazon (Caso 2 del PDF): Dal 2014 al 2017, Amazon ha usato un sistema IA per valutare CV. Il modello — addestrato su 10 anni di CV prevalentemente maschili — ha imparato a svantaggiare sistematicamente le candidate, penalizzando CV con la parola “women’s”. Abbandonato nel 2017. Con l’AI Act oggi: classificato come alto rischio (Allegato III, punto 4: selezione CV per assunzioni); obbligatorio governance dei dati di addestramento, documentazione tecnica, sorveglianza umana. **Principio chiave:** i sistemi IA ereditano i bias nei dati — la tecnologia non è neutrale per definizione.

§7 — Rischio Limitato: Obblighi di Trasparenza

La legge sull’IA introduce **obblighi di divulgazione specifici** per garantire che gli esseri umani siano **informati** quando necessario. [fonte: PDF]

- Quando si utilizzano **chatbot**: gli utenti devono essere **consapevoli** di star **interagendo con una macchina**
- I fornitori di **IA generativa** devono garantire che i contenuti generati siano **identificabili**
- Alcuni contenuti generati dall’IA vanno **etichettati in modo chiaro e visibile**: deepfake e testi su questioni di interesse pubblico

§8 — Rischio Minimo o Nullo

La legge sull'IA **non introduce norme** per l'IA ritenuta a rischio minimo o nullo. La **stragrande maggioranza** dei sistemi di IA attualmente utilizzati nell'UE rientra in questa categoria. [fonte: PDF]

Esempi: videogiochi abilitati all'IA, filtri antispam.

§9 — Modelli di IA per Uso Generale (GPAI)

I modelli GPAI (General Purpose AI) sono **modelli addestrati su grandi quantità di dati**, capaci di svolgere un'**ampia gamma di compiti**: es. ChatGPT (OpenAI), Gemini (Google), Claude (Anthropic), LLaMA (Meta). [fonte: PDF]

Distinzione GPAI / sistema di IA correttamente segnalata da Lorenzo: un **modello GPAI** è il modello di base (es. GPT-4); un **sistema di IA** è il sistema che lo incorpora in un contesto specifico (es. un chatbot per il servizio clienti basato su GPT-4). Obblighi diversi per ciascuno.

Obblighi per i fornitori GPAI (dal 2 agosto 2025) [fonte: PDF]

- Redigere e aggiornare la **documentazione tecnica** del modello
- Rispettare la normativa sul **diritto d'autore** nei dati di addestramento e pubblicare una **sintesi pubblica dei contenuti formativi**

Modelli con rischio sistemico (“frontier models”) [fonte: PDF]

Obblighi aggiuntivi: **sicurezza, valutazione avversariale, segnalazione incidenti all'AI Office**.

Lorenzo ha chiesto: “(di che tipo di modelli si tratta? atti a cosa?)” I modelli a **rischio sistemico** sono i cosiddetti “frontier models” — i modelli più potenti e generali, addestrati su quantità di dati enormi (soglia indicativa: 10^{25} FLOP di calcolo di addestramento). Sono atti a svolgere un numero molto ampio di compiti ad alto livello di performance: generazione di testo, codice, immagini, audio, ragionamento complesso. Esempi concreti: GPT-4 (OpenAI), Gemini Ultra (Google), Claude Opus (Anthropic). Il rischio “sistemico” indica che un malfunzionamento o un uso illecito di questi modelli può avere effetti a cascata sull'intera infrastruttura digitale — non solo su un singolo utente.

Codice di buone pratiche GPAI (luglio 2025) [fonte: PDF]

Strumento **volontario** redatto da esperti indipendenti; l'**adesione costituisce presunzione di conformità**.

Vigilanza sui GPAI [fonte: PDF]

La **Commissione europea**, tramite l'**AI Office**, ha **competenza esclusiva** sui fornitori GPAI.

Lorenzo ha chiesto: “(cosa significa competenza esclusiva?)” **Competenza esclusiva** significa che solo la Commissione europea (tramite l’AI Office) può investigare e sanzionare i fornitori di modelli GPAI — le autorità nazionali degli Stati membri **non hanno giurisdizione** su di loro. Questo è diverso dai sistemi di IA ad alto rischio, dove sono le autorità nazionali a controllare. La ratio: i GPAI sono globali, sviluppati da pochissime grandi aziende internazionali; frammentare la vigilanza in 27 autorità nazionali sarebbe inefficace. I poteri sanzionatori diventano pienamente operativi il **2 agosto 2026**.

§10 — Sanzioni

Fascia	Violazione	Importo
Fascia 1	Violazioni dei divieti (pratiche vietate, art. 5)	Fino a 35.000.000 € o 7% del fatturato mondiale annuo
Fascia 2	Altre violazioni (es. obblighi sistemi ad alto rischio)	Fino a 15.000.000 € o 3% del fatturato mondiale annuo
Fascia 3	Informazioni false o fuorvianti alle autorità	Fino a 7.500.000 € o 1% del fatturato mondiale annuo

PMI e start-up: si applica il **minore** tra la soglia fissa e la percentuale sul fatturato (regime più favorevole). [fonte: PDF]

Sanzioni non pecuniarie: ritiro del sistema dal mercato, blocco immediato dell’utilizzo, cancellazione dai database. [fonte: PDF]

Cumulo con GDPR: le sanzioni AI Act si **cumulano** con quelle GDPR. [fonte: PDF]

Lorenzo ha chiesto: “questo perchè sempre di dati parliamo no?” Non solo per i dati — ma è un’intuizione parzialmente corretta. Il cumulo esiste perché i due Regolamenti **tutelano beni giuridici diversi**: il GDPR tutela la **riservatezza e i diritti degli interessati** rispetto ai loro dati personali; l’AI Act tutela la **sicurezza, i diritti fondamentali e la fiducia nell’IA** in quanto tale. Una violazione dell’AI Act (es. Clearview AI) può simultaneamente violare il GDPR (raccolta dati senza consenso) e l’AI Act (scraping facciale vietato) — due infrazioni distinte, due sanzioni distinte. La struttura a fasce percentuali sul fatturato è analoga per entrambi i Regolamenti: non è un caso, il GDPR ha fatto da modello.

Autorità di vigilanza: ogni Stato membro doveva designare l’autorità nazionale competente entro il 2 agosto 2025; la Commissione europea supervisiona i fornitori di modelli GPAI tramite l’AI Office. [fonte: PDF]

§11 — Digital Omnibus sull’IA (Aggiornamento 2026)

Il 19 novembre 2025 la Commissione ha proposto il “Digital Omnibus sull’IA”. Il **7 maggio 2026** Parlamento e Consiglio UE hanno raggiunto un **accordo politico provvisorio**. [fonte: PDF]

Principali modifiche [fonte: PDF]

Cosa	Prima	Dopo
Sistemi ad alto rischio standalone (Allegato III)	Scadenza 2 agosto 2026	Scadenza 2 dicembre 2027
Sistemi ad alto rischio embedded in prodotti (Allegato I)	Scadenza 2 agosto 2026	Scadenza 2 agosto 2028
Watermarking contenuti AI generativi	Scadenza 2 agosto 2026	Prorogato al 2 dicembre 2026 ; esenzioni estese a PMI
Nuovo divieto (deepfake intimi, CSAM)	Non previsto	Sistemi IA per generazione di immagini sessuali non consensuali — vietati dal 2 dicembre 2026

Cosa resta invariato [fonte: PDF]

I **divieti vigenti** (art. 5), gli **obblighi di alfabetizzazione IA** (art. 4) e gli **obblighi GPAI** restano invariati.

§12 — Orientamenti Etici per un'IA Affidabile

2018: la Commissione Europea istituisce un “**Gruppo indipendente di esperti ad alto livello sull’Intelligenza Artificiale**”. [fonte: PDF]

2019: il Gruppo pubblica gli “**Orientamenti etici per un'IA affidabile**”. [fonte: PDF]

Un'IA affidabile deve essere: [fonte: PDF] - a) **legale** (rispetto di tutte le leggi e i regolamenti applicabili) - b) **etica** (adesione a principi e valori etici) - c) **robusta** (dal punto di vista tecnico e sociale)

Principi Etici [fonte: PDF]

1. Rispetto dell'**autonomia umana**
2. **Prevenzione dei danni**
3. **Equità**
4. **Esplicabilità**

Requisiti di un'IA Affidabile (ALTAI) [fonte: PDF]

1. **Intervento e sorveglianza umani**
2. **Robustezza tecnica e sicurezza**
3. **Riservatezza e governance dei dati**
4. **Trasparenza**
5. **Diversità, non discriminazione ed equità**
6. **Benessere sociale e ambientale**
7. **Accountability**

ALTAI [fonte: PDF]

Assessment List for Trustworthy AI — presentata nel luglio 2020. Strumento pratico che traduce gli orientamenti etici in una lista di controllo accessibile e dinamica per autovalutazione. Utilizzabile da sviluppatori e operatori.

Casi Pratici — Schema Riepilogativo

Lorenzo ha chiesto: “schematizza le violazioni dei casi pratici, in base a tipo di violazione, tipo di sanzione e rilevanza rispetto all’AI Act.”

Caso	Condotta	Pratica/Categoria AI Act	Fascia sanzionatoria	Cumulo GDPR
Clearview AI	Scraping 30 miliardi immagini facciali da internet senza consenso	Pratica vietata n. 5 (scraping facciale non mirato) + n. 8 (identificazione biometrica in spazi pubblici)	Fascia 1 — fino a 35M€ / 7% fatturato	Sì — già sanzionata per GDPR (Italia + Francia + NL 100M€)
Amazon CV screening	Sistema IA per selezione CV che discriminava le donne sistematicamente	Sistema ad alto rischio (Allegato III, punto 4: occupazione) — non pratica vietata	Fascia 2 — fino a 15M€ / 3% fatturato	Possibile (dati di dipendenti/candidati)
Manipolazione e-commerce	App che rileva vulnerabilità emotiva e attiva messaggi di scarsità fittizia	Pratica vietata n. 1 (tecniche manipolative)	Fascia 1 — fino a 35M€ / 7% fatturato	Eventuale (se raccoglie dati personali)
Social scoring e-commerce	Punteggio clienti su comportamento sociale → discriminazione su offerte e prezzi	Pratica vietata n. 3 (social scoring)	Fascia 1 — fino a 35M€ / 7% fatturato	Possibile (profilazione)

Caso	Condotta	Pratica/Categoria AI Act	Fascia sanzionatoria	Cumulo GDPR
Riconoscimento emozioni in azienda	Tentare di inferire emozioni dei dipendenti → valutare produttività	Pratica vietata n. 6 (inferenza emozioni al lavoro)	Fascia 1 — fino a 35M€ / 7% fatturato	Sì — dati biometrici = categoria sensibile art. 9 GDPR

Schema Riepilogativo — I 4 Livelli e i loro Regimi

Livello	Esempi	Regime
Inaccettabile	Social scoring, manipolazione, identificazione biometrica real-time in spazi pubblici, scraping facciale	Divieto assoluto (art. 5) — sanzione fino al 7% fatturato
Alto rischio	CV screening, credit scoring, chirurgia robotica, sentenze IA, esame domande visto	Obblighi rigorosi prima dell'immissione sul mercato — sanzione fino al 3%
Limitato	Chatbot, IA generativa, deepfake	Obblighi di trasparenza — dichiarare che è IA
Minimo/nullo	Videogiochi, filtri antispam	Nessuna norma specifica

Domande di Autoverifica

Le domande di autoverifica non erano presenti negli appunti grezzi come risposte — Lorenzo ha copiato le domande ma non le ha risposte. **D12 resta** fino all'autoverifica. Rispondere a queste 5 domande prima di portare D12 a .

1. Cos'è l'AI Act e qual è il suo oggetto? In quali casi non si applica?
2. Illustra i 4 livelli di rischio dell'approccio basato sul rischio. Fai un esempio concreto per ciascun livello e indica il regime normativo applicabile.
3. Elenca almeno 4 delle 8 pratiche vietate (rischio inaccettabile) e spiega il criterio comune che le accomuna. Sai distinguerle dai sistemi ad alto rischio?
4. Cosa si intende per modello GPAI? Quali obblighi gravano sui fornitori GPAI e come si differenziano da quelli dei fornitori di sistemi ad alto rischio?
5. Come funziona il sistema sanzionatorio dell'AI Act? Distingui le 3 fasce e spiega il rapporto con le sanzioni del GDPR. Cosa ha cambiato il Digital Omnibus del 2026 e cosa è rimasto invariato?